AI Racer Bug 报告

> 日期: 2026-05-01
> 范围: 根据 `TEST_MAINTENANCE_CHECKLIST.md` 完善测试时发现的源码与测试可靠性问题

概览

本次测试维护过程中发现了一个影响较高的源码安全问题，以及若干会掩盖真实回归的测试套件可靠性问题。下列问题均在测试运行过程中复现，并已在当前工作区中补充对应修复或覆盖用例。

发现的问题

BUG-001: 提交的 Python 代码在静态安全检查前就可能被执行

- 严重级别: 高
- 所属模块: 后端代码提交校验
- 文件: `server/blueprints/submission.py`
- 现象: 学生提交的代码中如果包含危险导入或危险调用，系统没有先通过 AST 静态检查拒绝，而是进入了导入执行路径。
- 影响: 类似 `import os` 、 `import subprocess` 、 `__import__("sys")` 、 `open(...)` 、 `eval(...)` 、 `exec(...)` 的代码可能进入导入/校验流程。根据运行环境不同，这会削弱沙箱假设，并可能带来文件系统、进程或运行时访问风险。
- 根因: `_validate_code()` 只对临时文件做编译检查，并通过 `spec.loader.exec_module(module)` 导入执行模块；在执行模块顶层代码前，没有 AST 检查来拒绝禁用导入和危险调用。
- 修复: 在写入/导入临时模块前增加 AST 解析与校验，拦截禁用模块根名、危险内建调用，以及 `__builtins__` 访问。
- 回归测试:
  - `tests/backend/unit/test_submission.py::test_validate_code_forbidden_imports`
  - `tests/security/test_code_sandbox_escape.py`

BUG-002: 无效密码哈希会导致提交接口崩溃

- 严重级别: 中

- 所属模块: 后端认证
- 文件: `server/blueprints/submission.py`
- 现象: 如果 `teams` 表中的 `password_hash` 不是合法 bcrypt 哈希， `_verify_password()` 会抛出 `ValueError: Invalid salt` 。
- 影响: 数据库中的异常数据会把一次正常的认证失败变成 500 服务端错误。
- 根因: 没有处理 `_bcrypt.checkpw()` 抛出的异常。
- 修复: `_verify_password()` 捕获 `ValueError` 并返回 `False` ，保持“认证失败”的正常语义。
- 回归覆盖:
  - 完整安全测试套件现在会覆盖提交认证路径，并且不会因无效哈希崩溃。

BUG-003: 录像测试用例之间共享了残留文件

- 严重级别: 中
- 所属模块: 测试隔离
- 文件: `tests/backend/conftest.py`
- 现象: 录像测试可能读取到前一个测试创建的 metadata 或 telemetry 文件。
- 影响: 例如“录像列表为空”的测试会受到执行顺序影响，导致测试不稳定，并降低对录像功能的信心。
- 根因: 临时 `RECORDINGS_DIR` 和 `SUBMISSIONS_DIR` 在导入时创建，但每个测试开始前没有清理。
- 修复: 后端 autouse fixture 现在会在每个测试前清空并重新创建这两个目录。
- 回归测试:
  - `tests/backend/unit/test_recording.py`

BUG-004: 安全测试把明文当作 bcrypt 哈希使用

- 严重级别: 中
- 所属模块: 测试数据正确性
- 文件: `tests/security/test_code_sandbox_escape.py`
- 现象: 安全测试 fixture 将 `"hash"` 直接写入 `teams.password_hash` ，随后又用密码 `"hash"` 发起提交。
- 影响: API 在进入代码校验前就可能因密码哈希格式错误而崩溃，因此禁用导入相关测试并没有准确验证沙箱行为。
- 根因: 测试夹具中的数据格式与生产密码存储格式不一致。
- 修复: fixture 现在使用 `_hash_password("hash")` 存储密码哈希。
- 回归测试:
  - `tests/security/test_code_sandbox_escape.py`

BUG-005: 前端 E2E 的 server fixture 只在单个测试文件内定义，复用不可靠

- 严重级别: 中
- 所属模块: 前端 E2E 测试基础设施
- 文件:
  - `tests/frontend/e2e/conftest.py`
  - `tests/frontend/e2e/test_frontend_e2e.py`
- 现象: 多个 E2E 文件依赖 `server` fixture，但该 fixture 原本只定义在 `test_frontend_e2e.py` 中。
- 影响: 直接运行整个 E2E 目录会出现 “fixture 'server' not found”。部分测试只能在特定子集或特定顺序下运行。
- 根因: 共享 fixture 放在了单个测试模块里，而不是目录级 `conftest.py` 。
- 修复: 将 server fixture 移到 `tests/frontend/e2e/conftest.py` ，使用当前 Python 解释器启动 uvicorn，等待服务就绪，并预置默认 `zone1` 。
- 回归测试:
  - `tests/frontend/e2e`

BUG-006: E2E 选择器与实际 UI 文案不一致

- 严重级别: 低
- 所属模块: 前端 E2E 测试
- 文件:
  - `tests/frontend/e2e/test_complete_race_flow.py`
  - `tests/frontend/e2e/test_error_handling.py`
  - `tests/frontend/e2e/test_recording_playback.py`
- 现象: 测试点击的是 `button:has-text('Login')` ，但实际管理员 UI 的按钮文字是 `登录` 。
- 影响: 页面元素实际存在，但浏览器测试仍会因找不到英文按钮而超时。
- 根因: 测试选择器中的文案没有跟随本地化后的前端 UI 更新。
- 修复: 将选择器更新为实际中文登录文案。
- 回归测试:
  - `tests/frontend/e2e`

验证结果

修复后，完整测试套件通过:

```
PYTHONPATH=. .venv/bin/pytest tests -q
154 passed in 112.99s
```

剩余风险

- 当前 AST 沙箱使用的是静态 denylist，可以拦截已知危险导入和调用。若要获得更强隔离，提交代码仍应在单独的受限进程或容器中运行，并配置资源限制。
- 目前性能测试覆盖的是中等规模并发提交负载，尚未模拟持续的比赛级流量。